

15-Web Attack Forensics - Drone Alone

Introduction

The Story



La interfaz web del programador de drones de TBFC recibe solicitudes HTTP largas y extrañas que contienen fragmentos Base64. Splunk genera una alerta: "Apache generó un proceso inusual". En algunos endpoints, estas solicitudes hacen que el servidor web ejecute código shell, ofuscado y oculto dentro de las cargas útiles Base64. En esta sala, su trabajo como miembro del Equipo Azul consiste en clasificar el incidente, identificar los hosts comprometidos, extraer y decodificar las cargas útiles y determinar el alcance.

Utilizará Splunk para alternar entre los registros web (Apache) y la telemetría a nivel de host (Sysmon).

Siga los pasos de investigación a continuación; cada uno corresponde a una consulta de Splunk y un objetivo de investigación.

Objetivos de aprendizaje

- Detectar y analizar actividad web maliciosa a través de los registros de acceso y errores de Apache
- Investigar las acciones de los atacantes a nivel de sistema operativo utilizando datos de Sysmon
- Identificar y decodificar cargas útiles sospechosas u ofuscadas de los atacantes
- Reconstruir la cadena de ataque completa utilizando Splunk para la investigación del Equipo Azul

Answer the questions below

I have successfully started the AttackBox and the target machine!

No answer needed

Web Attack Forensics

Iniciar sesión en Splunk

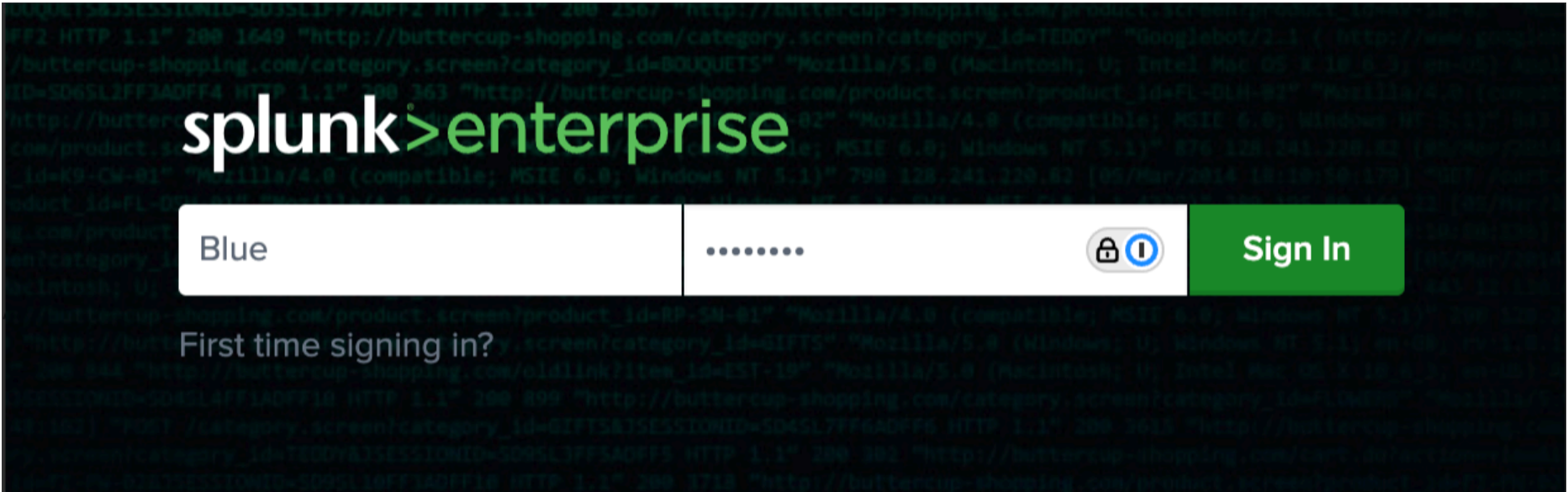
Después de iniciar AttackBox y la máquina de destino en la tarea anterior, espere unos 3 minutos para que el sistema arranque por completo. Luego, use Firefox en AttackBox para acceder al panel de Splunk en `http://MACHINE_IP:8000` con las credenciales que aparecen a continuación.

Credentials

To access Splunk dashboard

Username	Password	IP address	Connection via
Blue	Pass1234	MACHINE_IP	HTTP <code>http://MACHINE_IP:8000</code>

La página de inicio de sesión de Splunk debería verse similar a la captura de pantalla que se muestra a continuación.



Después de iniciar sesión correctamente, será llevado a la página de búsqueda como se muestra en la captura de pantalla a continuación.

splunk>enterpriseApps

blueMessagesSettingsActivityHelpFind

SearchAnalyticsDatasetsReportsAlertsDashboards

Search & Reporting

Search

enter search here...Time range: Last 24 hours

No Event SamplingSmart Mode

> Search History

How to Search

If you are not familiar with the search features, or want to learn more, or see your available data, see one of the following resources.

DocumentationTutorial

Analyze Your Data with Table Views

Table Views let you prepare data without using SPL. First, use a point-and-click interface to select data. Then, clean and transform it for analysis in Analytics Workspace, Search, or Pivot!

Learn more about Table Views, or view and manage your Table Views with the Datasets listing page.

Create Table View

Asegúrese de ajustar el rango de tiempo de Splunk para que incluya la hora de los eventos (p. ej., "Últimos 7 días" o "Siempre"). Si el rango predeterminado es demasiado estrecho, podría aparecer el mensaje "No se encontraron resultados".

Un Blue Teamer exploraría diversos ángulos de ataque a través de Splunk. En esta tarea, seguiremos al elfo Log McBlue, quien usa la magia de Splunk para desentrañar la ruta de ataque.

Detectar comandos web sospechosos

En el primer paso, buscaremos solicitudes HTTP que puedan mostrar actividad maliciosa. La siguiente consulta busca en los registros de acceso web cualquier solicitud HTTP que incluya indicios de intentos de ejecución de comandos, como `cmd.exe` , `PowerShell` o `Invoke-Expression` . Esta consulta ayuda a identificar posibles ataques de inyección de comandos, donde el atacante intenta ejecutar comandos del sistema a través de un script CGI vulnerable (`hello.bat`).

```
index=windows_apache_access (cmd.exe OR powershell OR "powershell.exe" OR "Invoke-Expression") | table _time host clientip uri_path uri_query status
```

New Search

Save AsCreate Table ViewClose

index=windows_apache_access (cmd.exe OR powershell OR "powershell.exe" OR "Invoke-Expression") | table _time host clientip uri_path uri_query statusTime range: Date time range

2 events (10/1/25 9:48:33.950 PM to 10/26/25 9:48:33.951 PM)No Event SamplingJobSmart Mode

EventsPatternsStatistics (2)Visualization

Show: 20 Per PageFormatPreview: On

_time	host	clientip	uri_path	uri_query	status
2025-10-26 21:48:33	WebAppServer	10.9.0.217	/cgi-bin/hello.bat	cmd=powershell.exe+-enc+VABoAGkAcwAgAGkAcwAgAG4AbwB3ACAATQ8pAG4AZQAhACAATQBVAEEASABBAEEASABBAEEA	200
2025-10-26 21:47:59	WebAppServer	10.9.0.217	/cgi-bin/hello.bat	cmd=cmd.exe	200

En este paso, nos interesan principalmente las cadenas codificadas en base64, que pueden revelar diversos tipos de actividad. Una vez que detecte los comandos de PowerShell codificados, decodifíquelos con [base64decode.org](https://www.base64decode.org) o su decodificador de base64 preferido para comprender qué intentaba hacer el atacante. Con base en los resultados obtenidos, copiemos la cadena de PowerShell codificada `VABoAGkAcwAgAGkAcwAgAG4AbwB3ACAATQ8pAG4AZQAhACAATQBVAEEASABBAEEASABBAEEA` y péguela en el campo superior de <https://www.base64decode.org/>. Luego, haga clic en "Decodificar", como se muestra en la captura de pantalla a continuación.

Decode from Base64 format

Simply enter your data then push the decode button.

VABoAGkAcwAgAGkAcwAgAG4AbwB3ACAATQBpAG4AZQAhACAATQBVAEEASABBAEEASABBAEEA

For encoded binaries (like images, documents, etc.) use the file upload form a little further down on this page.

UTF-8

Source character set.

☐

Decode each line separately (useful for when you have multiple entries).

Live mode OFF

Decodes in real-time as you type or paste (supports only the UTF-8 character set).

< DECODE >

Decodes your data into the area below.

Result goes here...

Búsqueda de errores del servidor o de ejecución de comandos en los registros de errores de Apache

En esta etapa, nos centraremos en inspeccionar los registros de errores del servidor web, ya que esto nos ayudará a detectar cualquier actividad maliciosa. Utilizaremos la siguiente consulta:

```
index=windows_apache_error ("cmd.exe" OR "powershell" OR "Internal Server Error")
```

Esta consulta inspecciona los registros de errores de Apache en busca de indicios de intentos de ejecución o fallos internos causados por solicitudes maliciosas. Como puede ver, buscamos mensajes de error con términos específicos como `cmd.exe` y `powershell`.

Asegúrese de seleccionar "View: Raw" en el menú desplegable sobre el campo "Event".

SearchAnalyticsDatasetsReportsAlertsDashboards

Search & Reporting

New Search

Save AsCreate Table ViewClose

index=windows_apache_error ("cmd.exe" OR "powershell" OR "Internal Server Error")Time range: Last 7 days

1 event (10/20/25 3:00:00.000 AM to 10/27/25 3:59:55.000 AM)No Event Sampling

JobPauseStopRefreshDownloadSmart Mode

Events (1)PatternsStatisticsVisualization

Timeline formatZoom OutZoom to SelectionDeselect

1 hour per column

FormatShow: 50 Per PageView: Raw

< Hide FieldsAll Fields

INTERESTING FIELDS# date_hour 1

iEvent

>[Sun Oct 26 21:48:33.950049 2025] [cgi:error] [pid 3716:tid 1084] [client 10.9.0.217:49347] AH01215: 'powershell.exe+-enc+VABoAGkAcwAgAGkAcwAgAG4AbwB3ACAATQBpAG4AZQAhACAATQBVAEEASABBAEEASABBAEEA' is not recognized as an internal or external command,\r: C:/Apache24/cgi-bin/hello.bat

Si una solicitud como `/cgi-bin/hello.bat?cmd=powershell` genera un error interno del servidor 500, suele significar que la entrada del atacante fue procesada por el servidor, pero falló durante la ejecución, una señal clave de intentos de explotación.

Comprobar estos resultados ayuda a confirmar si el ataque llegó al backend o permaneció bloqueado en la capa web.

Rastrear la creación de procesos sospechosos desde Apache

Exploremos Sysmon en busca de otros archivos ejecutables maliciosos que el servidor web podría haber generado. Lo haremos mediante la siguiente consulta de Splunk:

```
index=windows_sysmon ParentImage="*httpd.exe"
```

Esta consulta se centra en las relaciones entre procesos de los registros de Sysmon, específicamente cuando el proceso principal es Apache (`httpd.exe`).

Seleccione "View: Table" en el menú desplegable sobre el campo "Event".

index=windows_sysmon ParentImage="*httpd.exe"

Time range: Last 7 days

Q

✓ 12 events (10/20/25 4:00:00.000 AM to 10/27/25 4:16:56.000 AM)

No Event Sampling

Job

||■↷🖨️⬇️💡 Smart Mode

Events (12)

Patterns

Statistics

Visualization

🗒 Timeline format

➡ Zoom Out

+ Zoom to Selection

✖ Deselect

1 hour per column

🗒 Format

Show: 20 Per Page

View: Table

< Hide Fields	⋮ All Fields	i		_time	EventCode	_time	Computer	Image	CommandLine	User
SELECTED FIELDS 🔗 CommandLine 2 🔗 Computer 1 # EventCode 1 🔗 Image 2 🔗 User 1 INTERESTING FIELDS 🔗 Company 2 🔗 CurrentDirectory 2 🔗 Description 2 🔗 EventChannel 1 🔗 FileVersion 2		>	1	10/26/25 9:48:33.891 PM	1	2025-10-26T21:48:33.891+00:00	WebAppServer	C:\Windows\System32\cmd.exe	C:\Windows\system32\cmd.exe /C ""C:\Apache24\cgi-bin\hello.bat""	WEBAPPSERVER\apache_svc
		>	2	10/26/25 9:47:59.274 PM	1	2025-10-26T21:47:59.274+00:00	WebAppServer	C:\Windows\System32\cmd.exe	C:\Windows\system32\cmd.exe /C ""C:\Apache24\cgi-bin\hello.bat""	WEBAPPSERVER\apache_svc
		>	3	10/26/25 9:47:35.849 PM	1	2025-10-26T21:47:35.849+00:00	WebAppServer	C:\Windows\System32\cmd.exe	C:\Windows\system32\cmd.exe /C ""C:\Apache24\cgi-bin\hello.bat""	WEBAPPSERVER\apache_svc
		>	4	10/26/25 9:45:09.600 PM	1	2025-10-26T21:45:09.600+00:00	WebAppServer	C:\Windows\System32\cmd.exe	C:\Windows\system32\cmd.exe /C ""C:\Apache24\cgi-bin\hello.bat""	WEBAPPSERVER\apache_svc

Normalmente, Apache solo debería generar subprocessos de trabajo, no procesos del sistema como `cmd.exe` o `powershell.exe` .

Si los resultados muestran procesos secundarios como:

ParentImage = C:\Apache24\bin\httpd.exe

Image = C:\Windows\System32\cmd.exe

Esto indica una inyección de comandos exitosa donde Apache ejecutó un comando del sistema.

El hallazgo anterior es uno de los indicadores más sólidos de que el ataque web penetró el sistema operativo.

Confirmar la actividad de enumeración del atacante

En este paso, buscamos descubrir qué hacen los programas específicos que encontramos en consultas anteriores. Usemos la siguiente consulta:

index=windows_sysmon *cmd.exe* *whoami*

Esta consulta busca **registros de ejecución de comandos** donde `cmd.exe` ejecutó el comando `whoami` .

Los atacantes suelen usar el comando whoami inmediatamente después de obtener la ejecución del código para determinar en qué cuenta de usuario se ejecuta su proceso malicioso.

El hallazgo de estos eventos confirma el **reconocimiento posterior a la explotación** del atacante y muestra que el comando inyectado se ejecutó en el host.

New Search

Save As

Create Table View

Close

index=windows_sysmon *cmd.exe* *whoami*

Time range: Last 24 hours

Q

✓ 4 events (10/26/25 5:00:00.000 AM to 10/27/25 5:05:50.000 AM)

No Event Sampling

Job

||■↷🖨️⬇️💡 Smart Mode

Events (4)

Patterns

Statistics

Visualization

🗒 Timeline format

➡ Zoom Out

+ Zoom to Selection

✖ Deselect

1 hour per column

🗒 Format

Show: 20 Per Page

View: Table

< Hide Fields	⋮ All Fields	i		_time	EventCode	_time	Computer	Image	CommandLine	User	DestinationIp	Description
SELECTED FIELDS 🔗 CommandLine 1 🔗 Computer 1 # EventCode 1 🔗 Image 1 🔗 User 1 INTERESTING FIELDS 🔗 Company 1 🔗 CurrentDirectory 1 🔗 Description 1 🔗 EventChannel 1 🔗 FileVersion 1 🔗 Hashes 1		>	1	10/26/25 9:47:36.024 PM	1	2025-10-26T21:47:36.024+00:00	WebAppServer	C:\Apache24\cgi-bin\whoami.exe	whoami	WEBAPPSERVER\apache_svc		
		>	2	10/26/25 9:45:09.741 PM	1	2025-10-26T21:45:09.741+00:00	WebAppServer	C:\Apache24\cgi-bin\whoami.exe	whoami	WEBAPPSERVER\apache_svc		
		>	3	10/26/25 9:42:11.201 PM	1	2025-10-26T21:42:11.201+00:00	WebAppServer	C:\Apache24\cgi-bin\whoami.exe	whoami	WEBAPPSERVER\apache_svc		
		>	4	10/26/25 9:39:05.214 PM	1	2025-10-26T21:39:05.214+00:00	WebAppServer	C:\Apache24\cgi-bin\whoami.exe	whoami	WEBAPPSERVER\apache_svc		

Identificar cargas útiles de PowerShell codificadas en Base64

En este último paso, buscaremos todos los comandos codificados correctamente. Para buscar cadenas codificadas, podemos usar la siguiente consulta de Splunk:

index=windows_sysmon Image="*powershell.exe" (CommandLine="*enc*" OR CommandLine="*-EncodedCommand*" OR CommandLine="*Base64*")

Esta consulta detecta comandos de PowerShell que contienen texto en Base64 o en -EncodedCommand, una técnica común que utilizan los atacantes para **ocultar sus comandos reales**.

Si sus defensas están configuradas correctamente, esta consulta no debería devolver **ningún resultado**, lo que significa que la carga útil codificada (como el mensaje "Muahahaha") nunca se ejecutó.

Si aparecen resultados, puede decodificar el comando en Base64 para verificar la verdadera intención del atacante.

